ProjectFlow OWASP ZAP Scan report

Generated with ZAP on Tue 22 Sept 2026, at 16:04:03

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
  - Insights
- Alerts
  - Risk=Medium, Confidence=High (2)
  - Risk=Medium, Confidence=Medium (1)
  - Risk=Low, Confidence=Medium (2)
  - Risk=Low, Confidence=Low (1)

- Risk=Informational, Confidence=Medium (3)
- Appendix
  - Alert Types

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `http://192.168.1.8:3000`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `High`, `Medium`, `Low`, `Informational`

Excluded: None

Confidence levels

Included: `User Confirmed`, `High`, `Medium`, `Low`

Excluded: `User Confirmed`, `High`, `Medium`, `Low`, `False Positive`

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	2 (22.2%)	1 (11.1%)	0 (0.0%)	3 (33.3%)
	Low	0 (0.0%)	0 (0.0%)	2 (22.2%)	1 (11.1%)	3 (33.3%)
	Informational	0 (0.0%)	0 (0.0%)	3 (33.3%)	0 (0.0%)	3 (33.3%)
	Total	0 (0.0%)	2 (22.2%)	6 (66.7%)	1 (11.1%)	9 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://192.168.1.8:3000	0 (0)	3 (3)	3 (6)	3 (9)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	5 (55.6%)
Missing Anti-clickjacking Header	Medium	4 (44.4%)
Sub Resource Integrity Attribute Missing	Medium	5 (55.6%)
Total		9

Alert type	Risk	Count
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	5 (55.6%)
Timestamp Disclosure - Unix	Low	5 (55.6%)
X-Content-Type-Options Header Missing	Low	5 (55.6%)
Information Disclosure - Suspicious Comments	Informational	17 (188.9%)
Modern Web Application	Informational	3 (33.3%)
User Agent Fuzzer	Informational	5 (55.6%)
Total		9

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	94
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	246

Level	Reason	Site	Description	Statistic
Low	Exceeded High	http://192.168.1.8:3000	Percentage of responses with status code 4xx	58 %
Info	Informational		Percentage of network failures	2 %
Info	Informational	http://192.168.1.8:3000	Percentage of responses with status code 2xx	38 %
Info	Informational	http://192.168.1.8:3000	Percentage of responses with status code 3xx	2 %
Info	Informational	http://192.168.1.8:3000	Percentage of endpoints with content type application/javascript	52 %
Info	Informational	http://192.168.1.8:3000	Percentage of endpoints with content type image/x-icon	5 %
Info	Informational	http://192.168.1.8:3000	Percentage of endpoints with content type text/css	5 %
Info	Informational	http://192.168.1.8:3000	Percentage of endpoints with content type text/html	35 %
Info	Informational	http://192.168.	Percentage of endpoints with method	100 %

Level	Reason	Site	Description	Statistic
		1.8:3000	GET	
Info	Informational	http://192.168.1.8:3000	Count of total endpoints	17
Info	Exceeded Low	http://192.168.1.8:3000	Percentage of slow responses	48 %

Alerts

Risk=Medium, Confidence=High (2)

http://192.168.1.8:3000 (2)

Content Security Policy (CSP) Header Not Set (1)

▶ GET http://192.168.1.8:3000/login

Sub Resource Integrity Attribute Missing (1)

▶ GET http://192.168.1.8:3000/login

Risk=Medium, Confidence=Medium (1)

http://192.168.1.8:3000 (1)

Missing Anti-clickjacking Header (1)

▶ GET http://192.168.1.8:3000/login

Risk=Low, Confidence=Medium (2)

http://192.168.1.8:3000 (2)

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

▶ GET http://192.168.1.8:3000/login

X-Content-Type-Options Header Missing (1)

▶ GET http://192.168.1.8:3000/favicon.ico?c300fdc22246f7dd

Risk=Low, Confidence=Low (1)

http://192.168.1.8:3000 (1)

Timestamp Disclosure - Unix (1)

▶ GET http://192.168.1.8:3000/_next/static/chunks/app/(auth)/login/page.js

Risk=Informational, Confidence=Medium (3)

http://192.168.1.8:3000 (3)

Information Disclosure - Suspicious Comments (1)

▶ GET http://192.168.1.8:3000/_next/static/chunks/app/page.js

Modern Web Application (1)

▶ GET http://192.168.1.8:3000/login

User Agent Fuzzer (1)

▶ GET http://192.168.1.8:3000/

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

Source	raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID	497
WASC ID	13
Reference	▪ https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework

	▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	497
WASC ID	13
Reference	▪ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security_Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)

User Agent Fuzzer

Source	raised by an active scanner (User Agent Fuzzer)
Reference	▪ https://owasp.org/wstg